

TAREA BRS06

Configuración de dispositivos y sistemas informáticos I

Autor: Carlos España Del Pozo - CETI

Contenido

Apartado 1..... 3

Respuesta 1 4

Apartado 1

La red de tu organización ha crecido de manera descontrolada y permite a usuarios y administradores acceder a recursos sin pasar por sistemas de control adecuados. Esto genera importantes riesgos de seguridad: flujos de red inseguros, accesos laterales innecesarios y exposición de servicios críticos.

Dispones de los siguientes servicios y equipos:

- Web corporativa con BBDD (gestión de stock)
- Gestor de contenidos web
- Servidor de directorio activo
- Servidor DNS
- Servicio de impresión
- Servidor de ficheros
- Portal del empleado (Intranet con fuentes externas)

Objetivo

Rediseñar la arquitectura de red de la organización para:

1. Asegurar los flujos de comunicación.
2. Proteger los servicios expuestos.
3. Minimizar la superficie de ataque.
4. Aplicar principios del modelo Zero Trust y segmentación de red.
5. Equilibrar seguridad con costes, considerando que solo hay 2 personas en el equipo de ciberseguridad.

Qué debes hacer

1. Segmentación lógica de red
 - Define las VLANs necesarias para separar servicios, usuarios y zonas de red.
 - Justifica cada VLAN indicando su función, nivel de exposición y por qué debe estar aislada.
 - Incluye etiquetas de VLAN y subredes asignadas.
2. Servicios expuestos en la DMZ
 - Identifica qué servicios deben estar en la zona desmilitarizada (DMZ).
 - Justifica su colocación según riesgos y necesidades de acceso desde internet o zonas no seguras.
3. Migración de un servicio a la nube
 - Elige uno de los servicios y plantea cómo podría estar en una infraestructura cloud pública o híbrida.
 - Justifica la elección.
 - Indica medidas de seguridad necesarias (cifrado, autenticación, integridad, acceso VPN, etc.).

4. Diseño de firewalls y control de flujos
 - Indica cuántos firewalls implementarías y su ubicación.
 - Describe qué flujos controlarían (nivel de red).
 - Para cada firewall, indica al menos una regla IPTABLES o ACL con este formato:
 - IP origen - IP destino - puerto - protocolo – acción
5. Ubicación de componentes de seguridad
 - Dibuja en el diagrama y justifica la ubicación estratégica de:
 - Switches
 - Routers
 - Firewalls
 - Proxys
 - IDS/IPS
6. Diseño visual
 - Representa todo el diseño en un diagrama de red completo, claro y con leyenda.
 - Puedes usar herramientas como Draw.io, Lucidchart, Canva, o incluso hacerlo a mano si está escaneado y legible.
 - El diagrama debe mostrar:
 - Segmentación por VLANs
 - Servicios en DMZ
 - Zona interna
 - Zona de empleados
 - Servicios en la nube (si los hay)
 - Dispositivos de red y seguridad

Respuesta 1

Primero de todo revisaremos el adaptador de red desde el dispositivo que tiene acceso al router:

1. Definición de VLANs

Para cumplir con el principio de segmentación de redes y mínimo privilegio, es fundamental dividir la infraestructura en segmentos lógicos de red aislados.

Para ello primero definiremos las siguientes VLANs:

VLAN 10: Servicios accesibles desde Internet. Debe estar aislada para que un compromiso aquí no afecte a la red interna.

VLAN 20: Contiene activos core y datos corporativos. Requiere aislamiento total del tráfico externo directo.

VLAN 30: Accede al exterior, pero contiene datos internos. El aislamiento evitará ataques de movimientos laterales.

VLAN 40: Dispositivos con seguridad limitada que no deben comunicarse con servidores críticos.

VLAN	Nombre	Subred	Servicios / Usuarios	Exposición
VLAN 10	DMZ (Pública)	192.168.10.0/24	Web corporativa, Gestor de contenidos web, Servidor DNS.	Alta exposición
VLAN 20	Gestión Core	192.168.20.0/24	Directorio Activo, Servidor de Ficheros.	Exposición nula
VLAN 30	Usuarios e Intranet	192.168.30.0/24	Portal del Empleado, Equipos de trabajo.	Exposición media
VLAN 40	Periféricos	192.168.40.0/24	Servicio de impresión.	Baja exposición

2. Servicios en la Zona Desmilitarizada (DMZ)

Los servicios que deben ubicarse obligatoriamente en la **DMZ** son aquellos que requieren ser accesibles desde zonas externas poco seguras (Internet):

- **Web corporativa con BBDD:** Para que los clientes consulten la web corporativa desde internet
- **Gestor de contenidos web:** Permite actualizaciones de contenido, a menudo desde fuentes externas o internas.
- **Servidor DNS:** Específicamente el DNS externo para la resolución de nombres de la organización desde Internet.

Estos servidores son los más susceptibles a ataques por tener accesos desde el exterior de la organización. Al situarlos en una red aislada, si un ciberdelincuente vulnera la web, el firewall bloqueará cualquier intento de conexión desde la DMZ hacia la red local (VLAN 20), mitigando de forma activa cualquier ataque o acción dañina para nuestra organización.

3. Propuesta de Infraestructura Cloud

En mi opinión el activo que pudiera ser más fácil de migrar a un entorno “As a Service” sería la **Web corporativa con BBDD**, el cual se podría desacoplar de nuestro entorno on-premise y para migrar a una infraestructura cloud pública.

Un servicio de cloud pública nos ofrece mayor disponibilidad y escalabilidad ante picos de demanda de usuarios, sin necesidad de aprovisionar tanto hardware, permitiendo delegar parte de la gestión de la privacidad y el hardware a proveedores especializados.

Se necesitarían implantar las siguientes medidas de seguridad:

- **Cifrado:** Implementación de HTTPS (TLS) para la web y cifrado de disco para la BBDD.
- **Autenticación e Integridad:** Uso de certificados digitales y claves rsa para asegurar que solo personal autorizado pueda acceder a modificar o actualizar los datos.
- **Acceso VPN:** El acceso administrativo desde la oficina a la nube debe realizarse a través de un túnel VPN con cifrado fuerte.

4. Implementación de Firewalls y Reglas

Para un nivel de seguridad ALTO, implementaría una Arquitectura de Protección de Perímetro de Tipo 5 (APP-5) utilizando dos firewalls de distinto fabricante para evitar vulnerabilidades comunes.

- Firewall 1 (Frontera Externa): Ubicado entre Internet y la DMZ. Controla el acceso del público a los servicios web.
- Firewall 2 (Frontera Interna): Ubicado entre la DMZ y la Red Interna (VLAN 20/30). Controla que la DMZ no inicie conexiones hacia dentro.

ACL de los FIREWALLS

Firewall	IP Origen	IP Destino	Puerto	Protocolo	Acción
Externo	ALL (Internet)	192.168.10.10 (Web)	443	TCP	ALLOW
Interno	192.168.30.0/24 (Usuarios)	192.168.20.5 (File Server)	445	TCP	ALLOW
Interno	192.168.10.0/24 (DMZ)	192.168.20.0/24	ALL	ALL	DENY

La última regla es crítica para cumplir con la prohibición de conexiones desde la DMZ hacia la red local

5. Ubicación de componentes de seguridad

La ubicación estratégica de los componentes de red y seguridad, aplicando Zero Trust y teniendo en cuenta que el equipo de ciberseguridad es reducido priorizaremos la simplicidad operativa: simplicidad operativa.

- **Switches:**
Tendremos un switch core en la red interna conectado al firewall interno (Capa 3) y un switch por cada segmento de vlan (capa 2).
- **Routers:**
Disponemos de un router principal conectado al ISP.
- **Firewalls:**
Tendremos dos firewalls (como aconseja el ENS a nivel de seguridad alto).

Firewall Perimetral Externo para controlar todo el tráfico entrante desde Internet y limitar superficie de ataque.

Firewall Interno para evitar movimientos laterales y controlar accesos específicos entre usuarios y servicios core.

- **Proxys:**
Conectado antes del firewall externo para navegación de usuarios y filtrado de contenidos.
- **IDS/IPS:**
IDS pasivo entre el Firewall Externo y la DMZ.
IPS integrado en el Firewall Interno.

6. Diseño visual

